

THiNK Responsible AI Governance Framework

1. Our Purpose

At THiNK, we recognize that Artificial Intelligence (AI) is a powerful technology that can significantly improve our research, productivity, and the quality of our client work. We use AI internally for tasks like content creation, software development, and analysis, and we also develop and operate a specialized internal AI model to assess other AI systems and agentic bots.

We also understand that AI introduces significant risks, including bias, security vulnerabilities, privacy violations, and inaccurate outputs. This framework establishes the principles, governance, and controls to ensure we use and evaluate AI responsibly.

Our ultimate goal is to build an auditable AI governance system where AI systems are governed according to their purpose, risk, and potential impact, with human accountability maintained throughout their lifecycle.

2. Who This Applies To

This framework applies to everyone at THiNK: every employee, contractor, intern, and third-party who develops, accesses, or operates AI systems on our behalf. It covers everything from using an AI writing assistant to developing our own proprietary assessment models.

3. Our Guiding Principles

All our work with AI is guided by a set of core principles that ensure we remain responsible and trustworthy.

- a. Human Accountability is Paramount: AI systems do not hold responsibility. Our people do. An employee cannot blame an AI for an error. Where AI contributes to a professional conclusion, the human remains accountable for the final outcome.
- b. Purpose and Proportionality: We only use AI for legitimate, documented purposes. The level of governance applied is proportionate to the potential risk. A low-risk task like grammar checking requires fewer controls than a high-risk autonomous assessment.

- c. **Safety, Reliability, and Security:** Our AI systems are designed and operated with safeguards against erroneous outputs, malicious attacks, and unauthorized access. We treat AI security as a core part of our cybersecurity posture.
- d. **Privacy and Data Protection:** All AI processing respects applicable data protection laws, including Kenya's Data Protection Act, 2019. Personal or sensitive information is only processed through AI systems when necessary and with appropriate safeguards in place.
- e. **Fairness, Transparency, and Explainability:** We work to prevent unjustified bias in our AI systems. We are transparent about our use of AI and can explain how it contributes to our work, especially for significant decisions.

4. How We Govern AI

Executive Management is ultimately accountable and provides the necessary resources. The THiNK Lab oversees our AI strategy, approves high-risk systems, and manages major incidents. Every significant AI system has a designated System Owner responsible for its risk, performance, and documentation.

We maintain a comprehensive AI System Register that tracks every significant AI system we use or develop, detailing its purpose, risk classification, security controls, and approval status. This ensures we always know what AI is in our environment.

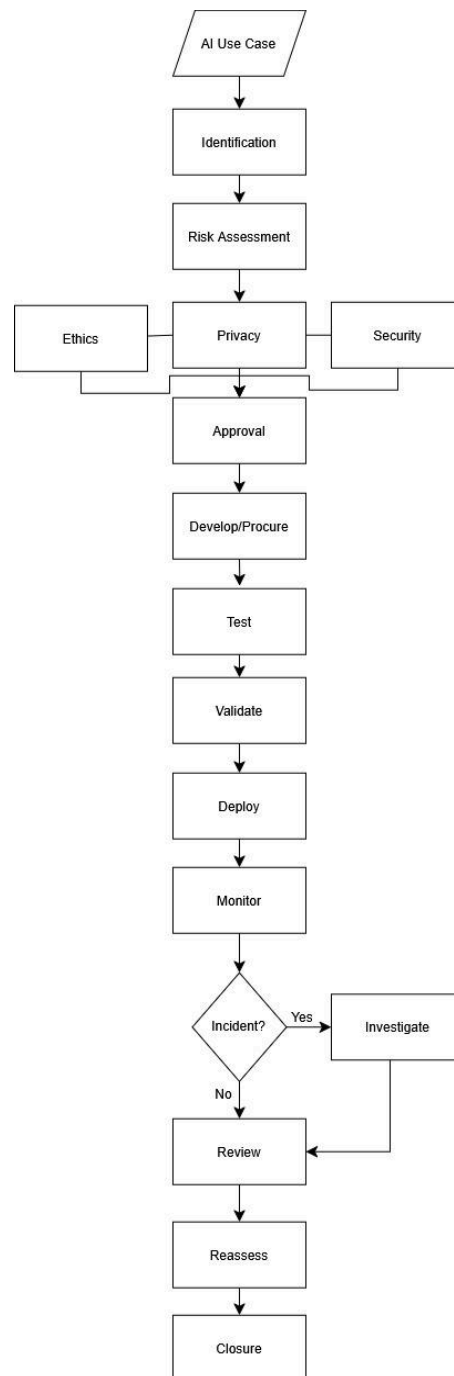
5. Classifying AI by Risk

Not all AI is created equal. We classify every AI system based on its potential impact. This determines the level of governance and oversight it requires.

- **Low Risk:** Tasks like brainstorming or grammar checking that have minimal impact.
- **Moderate Risk:** Systems for internal data analysis or software development assistance that require standard oversight.
- **High Risk:** Systems used for consequential assessments or those processing sensitive information, which require formal risk assessments and documented human review.
- **Critical Risk:** Systems whose failure could lead to significant legal, security, or safety consequences. These are restricted and require explicit executive approval.

6. The AI Lifecycle

We manage our AI systems through a controlled lifecycle. Every system goes through a process of identification, risk assessment, approval, testing, deployment, continuous monitoring, and eventual retirement. This ensures that we don't just deploy AI and forget about it; we actively manage it throughout its life.



7. Using AI for Internal Work

Our employees are encouraged to use approved AI systems to enhance their productivity and work quality. This includes using AI for research, drafting, code generation, and data analysis.

However, this comes with responsibilities. The user is always responsible for verifying the accuracy of AI-generated outputs. AI-generated content, including code, must be reviewed by a qualified human before it is used in production or shared externally. We prohibit the use of AI for illegal activities, disclosing company secrets, or making unauthorized decisions on behalf of THiNK.

8. Securing Our AI and Data

We implement strong security measures to protect our AI systems. This includes principles like least privilege (giving AI only the permissions it needs), access controls, and regular security testing.

We strictly enforce data classification rules. For example, highly confidential information like customer records, private keys, and security vulnerabilities must never be processed by unapproved AI systems. Employees must be mindful of what they input into AI tools.

9. Special Governance: Our Internally Developed Assessment Model

Our internal AI assessment model is a sophisticated system that we develop and operate, and it must be governed with the highest standards. It is subject to all the lifecycle and risk-management requirements described above, plus more.

We view our assessment model as an evaluation instrument, not an autonomous authority. It is a powerful tool that assists our expert assessors, but it does not make final decisions. We maintain comprehensive documentation for the model, covering its purpose, architecture, training data, known limitations, and performance metrics.

10. How We Assess Agentic Bots

Our Agentic Bot Assessment process is a controlled methodology where we use our internal AI model to evaluate other AI systems. The process is designed with multiple layers of human oversight to ensure integrity and quality.

Assessors use the AI model to execute test cases, analyze responses, and identify potential vulnerabilities. The AI can also help score and summarize evidence. However, all significant AI-generated findings must be reviewed and validated by a qualified human assessor.

The final conclusion on an assessed bot is always determined by a human, not the AI.

We also ensure the assessment process is independent. The assessment environment is controlled so that the assessed bot cannot improperly influence the AI evaluator. This protects the integrity of our work.

11. AI Incidents: When Things Go Wrong

We have a formal process for managing AI incidents, which are events where an AI system causes harm or malfunctions. This could be anything from an AI generating discriminatory output to a security breach of an AI system.

Our incident response process follows a clear path: Detect, Report, Contain, Investigate, Remediate, Validate, Document, and Learn. This ensures we can quickly stop the harm, understand the cause, and prevent it from happening again.

12. Our Commitment to Continuous Improvement

The field of AI is evolving rapidly, and so is our governance. We don't treat this framework as a static document. We continuously monitor our AI systems' performance, review emerging threats, and adapt to new laws and regulations. We provide regular AI literacy and security training to all employees.

We also conduct periodic audits to ensure we are complying with this policy and that our AI governance is effective. We are committed to maintaining a culture of responsibility and accountability around AI.

13. The Core of Our Governance: Three Key Categories

To simplify our governance, we categorize our AI activities into three main areas, each with its own set of primary risks.

Category A: Internal Use of AI

- Examples: Research, writing, coding, productivity tools.
- Primary Risks: Privacy, confidentiality, hallucination, intellectual property infringement, and over-reliance.

Category B: AI-Created Content

- Examples: Reports, presentations, marketing materials, and code.
- Primary Risks: Factual accuracy, intellectual property, reputational harm, and quality.

Category C: AI in Audits, Evaluations, and Assessments

- Examples: Evaluating bots and AI systems for security and compliance.
- Primary Risks: False or biased findings, loss of evidence integrity, and professional accountability.

Our internally developed assessment model and agentic AI systems are governed with an even higher level of scrutiny due to their specialized nature and inherent risks.

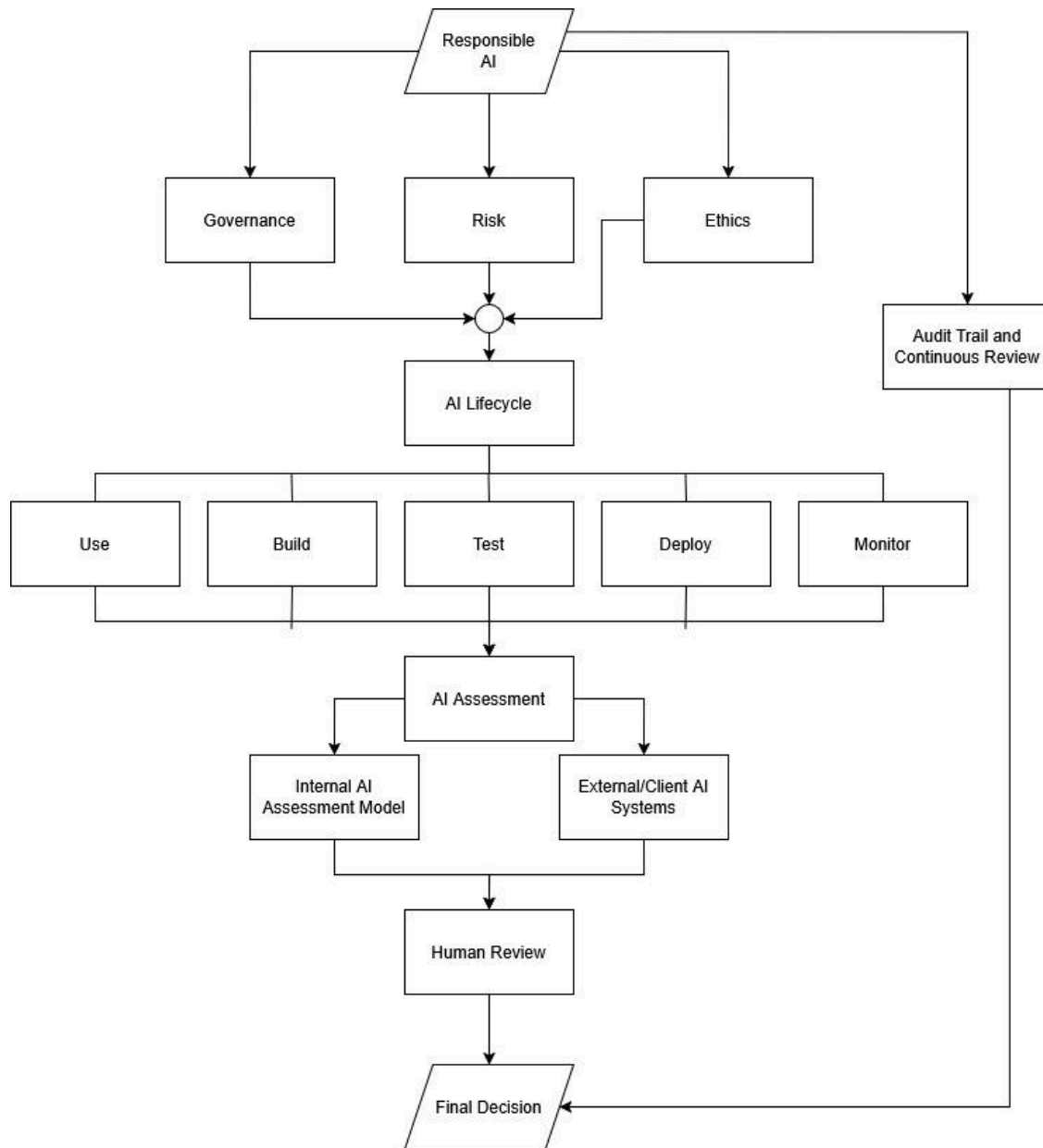
14. The Golden Rule

Every decision we make and every system we build is guided by this single, non-negotiable principle:

AI may assist, analyze, test, recommend, and automate within approved boundaries, but accountability, authority, and professional judgment remain with authorized humans.

And for our specialized Agentic Bot Assessment program:

The organization's AI assessment model is an evaluation instrument, not an autonomous authority. Assessment conclusions must be supported by evidence, reproducible methodology, and appropriate human review.



15. Developed under the guidance of:

ISO/IEC 42001 — Artificial Intelligence Management System: primary organizational governance framework - [ISO/IEC 42001 — AI Management Systems](#)

ISO/IEC 23894 — AI Risk Management AI-specific risk-management processes - [ISO/IEC 23894 — AI Risk Management](#)

NIST AI RMF: Uses Govern, Map, Measure and Manage as a practical risk-management model - [NIST AI Risk Management Framework](#)

NIST Generative AI Profile: risks specific to or amplified by generative AI - [NIST Generative AI Profile](#)

OWASP GenAI Security Project: The technical security layer, particularly for LLM and agentic applications. - [OWASP GenAI Security Project](#)

Kenya AI Strategy 2025–2030: aligning organizational AI governance with the country's broader AI direction - [Kenya AI Strategy 2025–2030 — Ministry of ICT](#)

ETICAS Responsible AI Usage Policy - [ETICAS](#)